

REPUBLIC OF CYPRUS

OFFICE OF THE COMMISSIONER FOR PERSONAL DATA PROTECTION

Kypranoros 15, 1061 NICOSIA / P.O. Box 23378, 1682 Nicosia – Cyprus, Tel: 22818456, Fax: 22304565

E-mail: commissioner@dataprotection.gov.cy, Website: <http://www.dataprotection.gov.cy>

COMMISSIONER

File No.:

12.10.001.011.006.005.032

DECISION

Incident of personal data breach regarding the posting of identity card numbers of educational staff

I refer to the Notification of the personal data breach incident registered in my Office on April 21, 2023, regarding the posting of identity card numbers of educational staff on the website of the Education Service Commission and all related correspondence on the above matter, which forms part of the case file. In the context of examining the Notification based on the powers conferred upon me by Articles 33(5) and 55(1) of the Regulation of the European Parliament and of the Council on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, (EU) 2016/679 (hereinafter referred to as the "Regulation"), I found a violation of the Regulation by the Education Service Commission (hereinafter referred to as the "Commission") and, therefore, I issue this Decision.

A.

Incident

2. In the Notification form of the incident, as well as in the letter from the Service, dated September 7, 2023, in response to a letter from my Office, dated August 9, 2023, the following is stated:

2.1. On April 20, 2023, around 12:00 p.m., the Commission posted on its website the usual announcement with the transfer units of the educational staff,

2.2. The said announcement was in excel format,

2.3. In addition to the names, a column with the identity card numbers of the educators was inadvertently included,

2.4. "The error" was noticed on April 21, 2023, at 10:00 a.m., following a phone call received by the Service from an educational staff member,

2.5. The Commission immediately removed the column that included the identity card numbers of the educators.

3. The breach incident began on April 20, 2023, at 12:00 p.m. On April 21, 2023, at 10:00 a.m., the Commission became aware of it, and the incident ended at that same moment. The notification of the incident was made following a phone call from an educator.

4. Due to the incident, the following data were breached: name, identity card number, and file number. No special category data were breached.

5. The incident concerns data of approximately 11,300 employees, which were stored in five files.

6.1. The incident involves a breach of the confidentiality of personal data. Specifically, there may have been access to the data to a greater extent than was necessary or for which the individuals had given consent. However, the data related to the incident cannot be associated with other personal data of the same individuals and cannot be used for other potentially unlawful purposes.

6.2. The incident does not involve a breach of the availability of personal data.

6.3. The incident does not involve a breach of the integrity of the breached data.

7. The incident is due to human error. The nature of the incident has been identified as the publication/disclosure of data by mistake.

8. The nature of the potential consequences has been recorded as the disclosure of the identity card number of the educators. The Commission has assessed the severity of the potential consequences as minor.

9. Until the submission of the Notification form, as referred to therein, the Commission had not yet decided whether to inform the affected data subjects.

10. The Notification form did not state any measures taken prior to the incident.

11. Regarding the handling of the incident, the Commission immediately removed the files from its website. As stated in the Notification form, the Commission intended to review the procedures concerning the publication of announcements or data of educators on its website, with the aim of minimizing, as much as possible, the exposure of their data for the purposes of full compliance with the Regulation, always taking into account the provisions of the legislation concerning the operation of the Commission.

12. The procedure followed before the incident was the creation of an excel file that included various categories of data of the educational staff, and subsequently, it was determined which columns would be retained. Additionally, the person responsible for creating the file and the announcement, as well as for the...

3

The publication on the Commission's website was made by a single official, without any verification by another official prior to the posting.

13.

The Commission is unable to technically determine how many times and/or if the said files were downloaded. However, it is aware that during the period the announcement was posted, twenty individuals visited the Commission's website. Nevertheless, this does not necessarily mean that all twenty individuals had access to the said announcement. In other words, the website traffic was low when the announcement was posted.

14.

The Commission decided not to inform the affected data subjects about the breach incident because it assessed that the severity of the consequences of the breach was low, due to the limited duration that the said announcement was posted on the Commission's website and the fact that the website traffic during that period was also low. Furthermore, the Commission did not receive any other relevant complaints.

15.

In hindsight, and in light of the incident, the Commission found that no measures had been taken prior to the incident that could have prevented the possibility of human "error" to avoid the incident and/or limit the breach. Therefore, as a corrective measure, the Commission decided that the creation of the Excel file would be done from scratch by creating columns that would contain only the required categories of data for publication. Additionally, a check would be conducted before the announcement was published on the website by the responsible administrative officer, who would be different from the official responsible for preparing the file.

16.

The severity of the potential consequences was determined to be low, as the duration that the said announcement was posted on the Commission's website was limited and the website traffic during that period was also low.

17.

The Commission has not received any complaints and/or updates from affected data subjects, other than the educator who informed the Commission on April 21, 2023, at 10:00 a.m.

18.

At this point, I note that as soon as it was realized by the Commission that the identification numbers of

the educators were posted on the Commission's website, and before the submission of the Notification Form, the Chairman of the Commission contacted my Office by phone, informing me, as well as an official from my Office, about the incident, stating that immediate instructions were given for the removal of the said files and that these files had already been removed.

B.

Legal Framework

19.

According to Article 4 of the Regulation, personal data is interpreted as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, or data...

4

position, in an online identifier or in one or more factors that are specific to the physical, physiological, genetic, psychological, economic, cultural, or social identity of that natural person."

Pursuant to the same article, a personal data breach is defined as "a security breach that leads to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed."

Also, in the same article, the data controller is defined as "the natural or legal person, public authority, agency, or other body that, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union law or the law of a Member State, the data controller or the specific criteria for its designation may be provided for by Union law or the law of a Member State."

20.

Pursuant to Article 24 of the Regulation, the following is provided:

"1.

Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is performed in accordance with this Regulation. These measures shall be reviewed and updated when necessary.

2.

Where appropriate in relation to the processing activities, the measures referred to in paragraph 1 shall include the implementation of appropriate policies for the protection of data by the data controller."

21.

Additionally, for the security of processing, Article 32 of the Regulation provides, among other things, that:

"1.

Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, among others, as appropriate:

a)

the pseudonymization and encryption of personal data,

b)

the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services,

c)

the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident,

d)

a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures for ensuring the security of processing.

2.

In assessing the appropriate level of security, account shall be taken, in particular, of the risks that are presented by the processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed."

22.

Pursuant to Article 58(2) of the Regulation, the Data Protection Commissioner has the following corrective powers:

"a)

to issue warnings to the data controller or the processor that intended processing operations are likely to infringe provisions of this Regulation,

b)

to issue reprimands to the data controller or the processor when processing operations have infringed provisions of this Regulation,

c)

to order the data controller or the processor to comply with the requests of the data subject to exercise their rights under this Regulation,

d)

to order the data controller or the processor to bring processing operations into compliance with the provisions of this Regulation, if necessary, in a specific manner and within a specified period,

e)

to order the data controller to notify the personal data breach to the data subject,

f)

to impose a temporary or definitive limitation, including a ban on processing,

g)

to order the rectification or erasure of personal data or restriction of processing pursuant to Articles 16, 17, and 18 and to order notification of such actions to recipients to whom the personal data have been disclosed pursuant to Article 17(2) and Article 19,

h)

to withdraw a certification or to order a certification body to withdraw a certificate issued pursuant to Articles 42 and 43 or to order a certification body not to issue a certification, where the certification requirements are not or are no longer met,

i)

to impose an administrative fine pursuant to Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the circumstances of each individual case,

j)

to order the suspension of the flow of data to a recipient in a third country or to an international organization."

23.

Article 83 of the Regulation, regarding the general conditions for imposing administrative fines, provides that:

"1.

Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this Article for infringements of this Regulation is...

6

The provisions referred to in paragraphs 4, 5, and 6 must be effective, proportionate, and deterrent for

each individual case.

2. Administrative fines, depending on the circumstances of each individual case, are imposed in addition to or instead of the measures referred to in Article 58, paragraph 2, points (a) to (h) and in Article 58, paragraph 2, point (i). In making a decision regarding the imposition of an administrative fine, as well as regarding the amount of the administrative fine for each individual case, the following shall be duly taken into account:

- (a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the relevant processing, as well as the number of data subjects affected by the infringement and the degree of damage suffered,
- (b) the intent or negligence that caused the infringement,
- (c) any actions taken by the data controller or the processor to mitigate the damage suffered by the data subjects,
- (d) the degree of responsibility of the data controller or the processor, taking into account the technical and organizational measures they have implemented under Articles 25 and 32,
- (e) any relevant previous infringements by the data controller or the processor,
- (f) the degree of cooperation with the supervisory authority in remedying the infringement and mitigating its possible adverse effects,
- (g) the categories of personal data affected by the infringement,
- (h) the manner in which the supervisory authority became aware of the infringement, in particular whether and to what extent the data controller or the processor notified the infringement,
- (i) in cases where measures referred to in Article 58, paragraph 2, were previously ordered against the involved data controller or processor concerning the same subject matter, compliance with those measures,
- (j) adherence to approved codes of conduct in accordance with Article 40 or approved certification mechanisms in accordance with Article 42, and
- (k) any other aggravating or mitigating factors arising from the circumstances of the specific case, such as the economic benefits gained or losses avoided, directly or indirectly, from the infringement.

3. In cases where the data controller or the processor, for the same or related processing operations, violates several provisions of this regulation, the total amount of the administrative fine shall not exceed the amount set for the most serious infringement.

4. Infringements of the following provisions shall incur, in accordance with paragraph 2, administrative fines of up to 10,000,000 EUR or, in the case of undertakings, up to 2% of the total worldwide annual turnover of the preceding financial year, whichever is higher:

- (a) the obligations of the data controller and the processor under Articles 8, 11, 25 to 39, and 42 and 43,
- (b) the obligations of the certification body under Articles 42 and 43,
- (c) the obligations of the monitoring body under Article 41, paragraph 4.

5. Infringements of the following provisions shall incur, in accordance with paragraph 2, administrative fines of up to 20,000,000 EUR or, in the case of undertakings, up to 4% of the total worldwide annual turnover of the preceding financial year, whichever is higher:

- (a) the basic principles for processing, including the conditions for consent, in accordance with Articles 5, 6, 7, and 9,
- (b) the rights of data subjects in accordance with Articles 12 to 22,
- (c) the transfer of personal data to a recipient in a third country or to an international organization in accordance with Articles 44 to 49,
- (d) any obligations under the law of the member state established under Chapter IX,
- (e) non-compliance with an order or with a temporary or definitive restriction of processing or with a suspension of data flows imposed by the supervisory authority under Article 58, paragraph 2, or failure to provide access in violation of Article 58, paragraph 1.

24. Regarding the imposition of an administrative fine, Article 32 of the Law on the Protection of Natural Persons Against the Processing of Personal Data and the Free Movement of Such Data of

2018, Law 125(I)/2018, provides that:

“(1) Subject to the provisions of Article 83 of the Regulation, the Commissioner imposes an administrative fine.

(...)

(3) An administrative fine imposed on a public authority or public body concerning non-profit activities may not exceed two hundred thousand euros (€200,000).”

C. Reasoning

25. For the specific processing activities, namely the preparation of the Excel files and their posting on the Commission's website, the Commission is the data controller, as it has determined the purposes and means of the processing.

26. Therefore, having the role of the data controller, the Commission must fulfill all obligations arising from the Regulation.

27. It is clear that the purpose of these processing activities was to inform educational officials regarding their transfer units. The Excel files included the full name, identity card number, and file number of each educator. It raises the question of whether the intended purpose, namely the informing of educational officials, could be achieved by processing fewer data.

8

28. In this context, it is established that the intended purpose could have been achieved without the processing, namely the posting, of the identification number of the educators. Therefore, the data being processed was not limited to what was necessary for the purpose for which it was processed, in violation of the principle of data minimization, namely Article 5(1)(c) of the Regulation.

29. The incident resulted in a breach of data concerning a large number of data subjects. However, the fact that these subjects were distributed across five files, which pertained to different levels of education, combined with the low traffic on the page when the announcement was posted, possibly limited the breach of personal data that occurred to some extent.

30. The Committee reported to my Office that the incident was due to human error and that the publication/disclosure of the data occurred inadvertently.

31. According to the procedure followed, only one official was responsible for creating and posting the announcement, who, from the original Excel file that contained various categories of data, retained only the columns that needed to be kept.

32. Based on the procedure mentioned by the Committee to my Office, I find that the incident is primarily due to a lack of organizational measures, specifically the absence of a procedure that would have prevented the occurrence of the incident and, subsequently, is due to human error.

33. Moreover, the fact that after the incident, the Committee established a procedure, according to which the creation of the Excel file will be done from scratch with the creation of only the necessary columns and, before its posting, a check will be conducted by another administrative official, indicates that there were measures that the Committee could have taken, which, however, it did not take.

34. Therefore, appropriate technical and organizational measures were not in place to ensure an adequate level of security against risks, in violation of Article 32(1) of the Regulation.

35. Furthermore, appropriate policies for the protection of data were not in place, in violation of Article 24(1) of the Regulation.

36. The Committee stated that the severity of the potential consequences is low, as both the time of posting the website and the number of visitors were small. Considering that the identification number is a unique identifier of the data subjects, which in any case was not necessary to be processed, I find that it is not true that the severity of the potential consequences was low, but that the likelihood of potential consequences is not great.

37. Furthermore, the Committee's position that the data concerning the incident cannot be related to other personal data of the same individuals and that they cannot be used for other potentially unlawful purposes is also not valid, since the said files included the names and surnames of the educational officials.

38. The fact that the Committee acted promptly after being informed by an educational official indicates that the Committee fully recognized the breach it committed. Additionally, the fact that there was direct involvement of the Committee at a high level, as the President of the Committee himself contacted my Office by phone to report the incident, confirms the importance that the Committee placed on both remedying the breach and fulfilling its obligations.

39. I recognize as a mitigating factor the fact that both the Committee, beyond the initial notification it received from an educational official, and my Office did not receive a complaint from another educational official.

40. However, I recognize as an aggravating factor the fact that the Notification form did not include measures taken before the incident.

D. Conclusion

41. Taking into account all the above elements, as they have been presented, and based on the powers conferred upon me by Articles 33(5) and 55(1) of the Regulation, I find that there is a violation by the Educational Service Committee:

(a) of Article 5(1)(c) of the Regulation, as the data being processed was not limited to what was necessary for the purpose for which it was processed, ("data minimization"),

(b) of Article 24(1) of the Regulation, as appropriate technical and organizational measures were not implemented to ensure and be able to demonstrate that the processing was carried out in accordance with the Regulation, and

(c) of Article 32(1) of the Regulation, as appropriate technical and organizational measures were not implemented to ensure an adequate level of security against risks.

42. Based on the provisions of Article 83 of the Regulation, regarding the conditions for imposing administrative fines, to the extent that they apply in this specific case, in determining the administrative fine, I took into account the following mitigating (a) - (h) and aggravating (i) - (j) factors:

(a) the absence of intent on the part of the Committee,

(b) the immediate actions taken by the Committee after the incident,

(c) the cooperation of the Committee with my Office, providing the requested information within the timelines I set,

(d) the involvement of the Committee in addressing the incident at a high level,

(e) the measures taken by the Committee to prevent the recurrence of the incident,

10

(στ) the fact that the data subjects whose data were breached were distributed across five files,

(ζ) the low traffic on the Commission's website and the short period during which the said files were posted,

(η) the category of data that was breached, which does not concern special categories of data,

(θ) the fact that my Office did not receive a relevant complaint, and that the Commission, apart from the initial notification, did not receive any other complaint from a data subject,

(ι) the fact that data of approximately 11,300 employees were breached,

(ια) the adherence to a procedure that was not capable of preventing the incident,

43.

Having taken into account and considered:

(α) the applicable legislative framework regarding the administrative sanctions provided for in the provisions of Article 58(2) and Article 83 of the Regulation,

(β) all the circumstances and factors that the Commission presented to me based on all existing correspondence,

(γ) the above mitigating and aggravating factors,

I find that, under the circumstances, the imposition of an administrative fine is not justified.

44.

Nevertheless, taking into account the above facts, the legal aspect on which this Decision is based, and the analysis as explained above, exercising the powers conferred upon me by Article 58(2)(b), (d) of the Regulation,

I have decided

in my judgment and in accordance with the above provisions,

to issue a reprimand to the Education Service Commission

for the violation of Articles 5(1)(c), 24(1), and 32(1) of Regulation (EU) 2016/679

and

to order that within two months from the receipt of this Decision:

(a) all staff of the Commission be trained in personal data protection legislation,

(b) further training be provided to employees who deal with the creation of files containing personal data of educational staff, which are posted on the Commission's website, in accordance with a written procedure that the Commission must submit to my Office,

(c) my Office be informed about the implementation of the above, by submitting relevant evidence.

Peace Loizidou Nicolaidou
Commissioner for the Protection
of Personal Data
July 3, 2024